Cyber Security

LJ University

- Deep Solanki

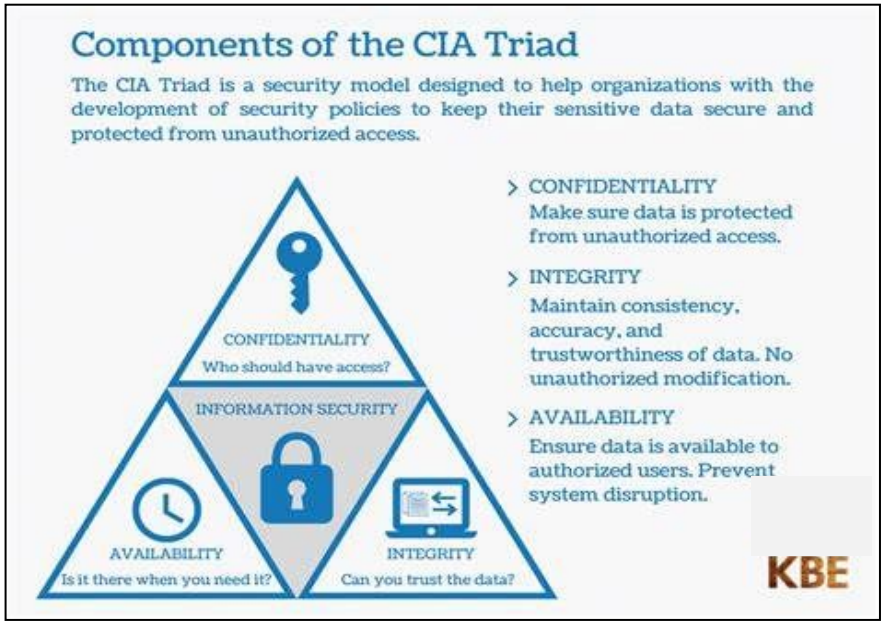
CIA



CIA Traid

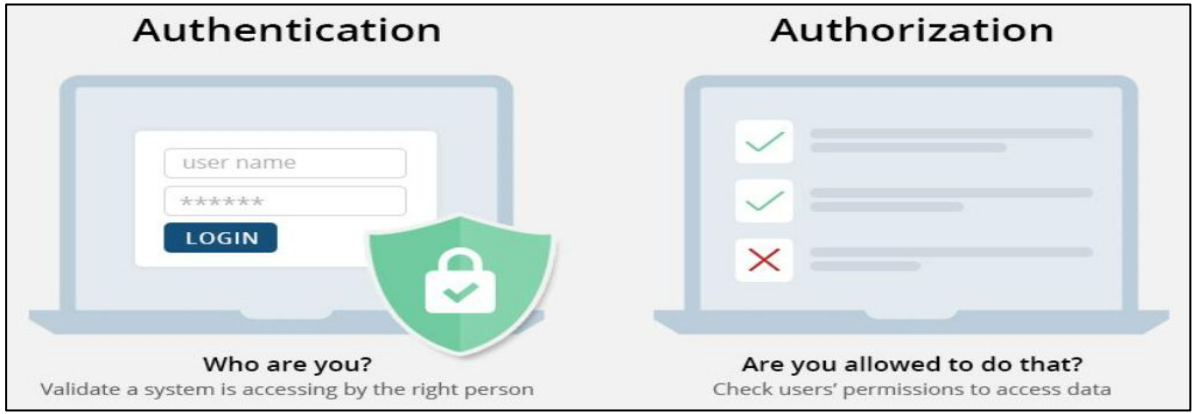
CIA Triad (Fundamental Concepts)

- **Confidentiality:** Ensures that data is accessible only to authorized users.
- **Integrity:** Protects data from being altered or tampered with by unauthorized users.
- **Availability:** Ensures that network services and resources are available to authorized users when needed.



Authorization and Authentication

- Authorization and authentication are two crucial concepts in security, often used together but serving different purposes.
- Authentication is about verifying identity, while authorization is about granting permissions based on that verified identity.



Authorization vs. Authentication

	Authentication	Authorization
Purpose	To verify the identity of a user or system.	To determine what an authenticated user or system is allowed to do.
Process	Determines if the user or system is who they claim to be.	Grants or denies permissions based on the user's identity and roles.
Methods	• Passwords • Biometrics (fingerprints, facial recognition) • Multi-factor authentication (combining two or more methods, like a password and a code sent to a phone) • Security tokens	• Access control lists (ACLs) • Role-based access control (RBAC) • Policy-based access control
Example	Logging into a website with a username and password.	Once logged into a website, accessing certain pages or performing certain actions (like viewing, editing, or deleting content) based on user roles (admin, editor, viewer).

Active vs. Passive Attack

- Active and passive attacks are two types of security breaches that differ in their methods and impacts on systems and data.
- Active attacks involve direct interference with systems to cause harm or gain control, while passive attacks focus on stealthily gathering information without altering the systems or data.

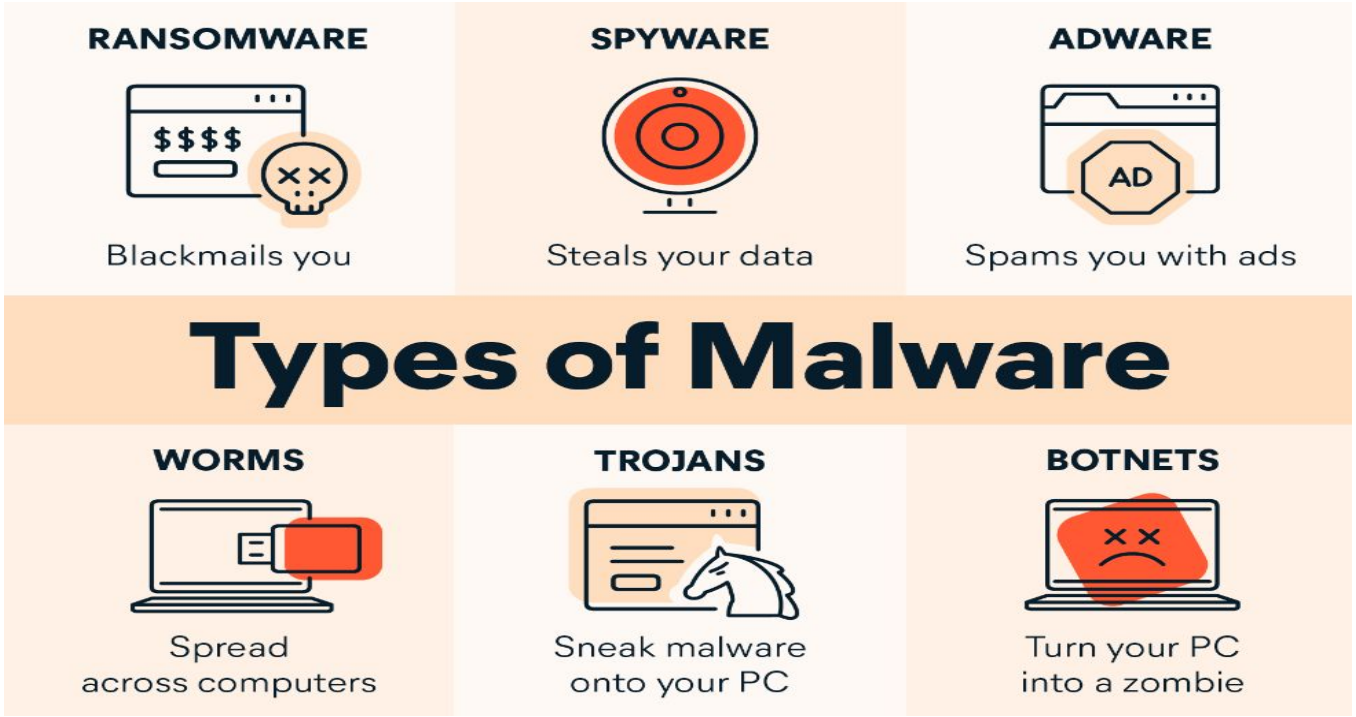
Active vs. Passive Attack

	Active Attack	Passive Attack
Nature	Involves direct interaction with the target system to alter its state or disrupt its normal operations.	Involves monitoring communications and data without altering them.
Goal	To modify, delete, or inject data, disrupt services, or gain unauthorized access to resources.	To gather information, such as sensitive data or communications, without detection.
Examples	• **Man-in-the-middle (MITM) attack**: Intercepting and altering communications between two parties. • **Denial of Service (DoS) attack**: Overloading a system to make it unavailable. • **SQL injection**: Inserting malicious SQL commands to manipulate a database. • **Malware deployment**: Introducing viruses, worms, or trojans to compromise systems.	• **Eavesdropping**: Listening to private communications over a network. • **Traffic analysis**: Monitoring the flow of data to infer information. • **Passive wiretapping**: Intercepting data traveling over networks without altering it.
Impact	Often immediate and noticeable, causing disruption, data loss, or system damage.	Often undetectable by the target, as the system and data remain unaltered, but can lead to significant security breaches if sensitive information is obtained.

Common Threats

- **Malware:** Malicious software such as viruses, worms, trojans, and spyware designed to damage or disrupt systems.
- **Social engineering:** Manipulation technique that exploits human psychology to gain access to confidential information, networks, or physical locations.
- **Denial of Service (DoS) Attacks:** Attempts to make a network service unavailable by overwhelming it with traffic.
- **Man-in-the-Middle (MitM) Attacks:** Interception and possible alteration of communication between two parties without their knowledge.
- **SQL Injection:** Exploiting vulnerabilities in an application's software by injecting malicious SQL commands.

Malware Attacks



Malware Attacks

- **Definition:** Malicious software designed to damage, disrupt, or gain unauthorized access to a computer system.
- **Types:**
  - **Viruses:** Attach themselves to legitimate programs and spread when the infected programs are executed.
  - **Worms:** Self-replicating malware that spreads without user intervention.
  - **Trojans:** Disguised as legitimate software but perform malicious actions once executed.
  - **Ransomware:** Encrypts the victim's data and demands a ransom for its decryption.
  - **Spyware**: Software that secretly monitors and collects information about a user's activities without their consent.

Malware Attacks

- **Definition:** Malicious software designed to damage, disrupt, or gain unauthorized access to a computer system.
- **Types:**
  - **Adware**: Software that automatically displays or downloads advertisements, often bundled with free programs.
  - **Keylogger**: Malicious software that records every keystroke made on a computer to steal sensitive information like passwords.
  - **Botnets**: Networks of compromised computers remotely controlled by attackers to perform malicious activities, often without the user's knowledge.
  - **Rootkit**: Malicious software that hides itself deep in your computer to secretly control it without you knowing.
  - **Backdoor**: A secret way for hackers to sneak into your computer without needing a password.

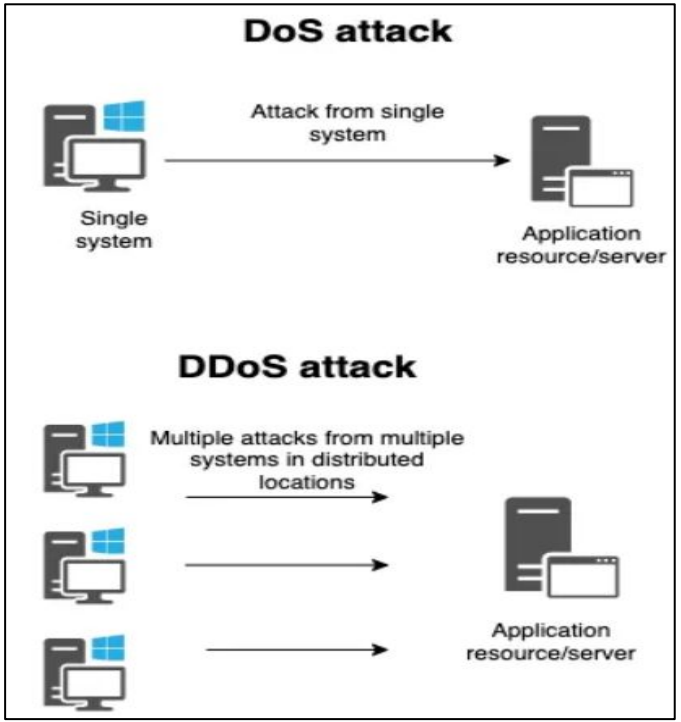
Attacks

- Network security attacks come in various forms, targeting different aspects of networks and systems.
  - Denial of Service (DoS) Attack
  - Distributed Denial of Service (DDoS) Attack
  - Man-in-the-Middle (MitM) Attack
  - Phishing Attack
  - Malware Attacks
  - SQL Injection Attack
  - Cross-Site Scripting (XSS) Attack
  - Brute Force Attack
  - Dictionary Attack
  - Credential Stuffing
  - Zero-Day Attack
  - Session Hijacking
  - Insider Threat &
  - Social Engineering Attacks

Denial of Service (DoS) and Distributed Denial of Service (DDoS) Attacks

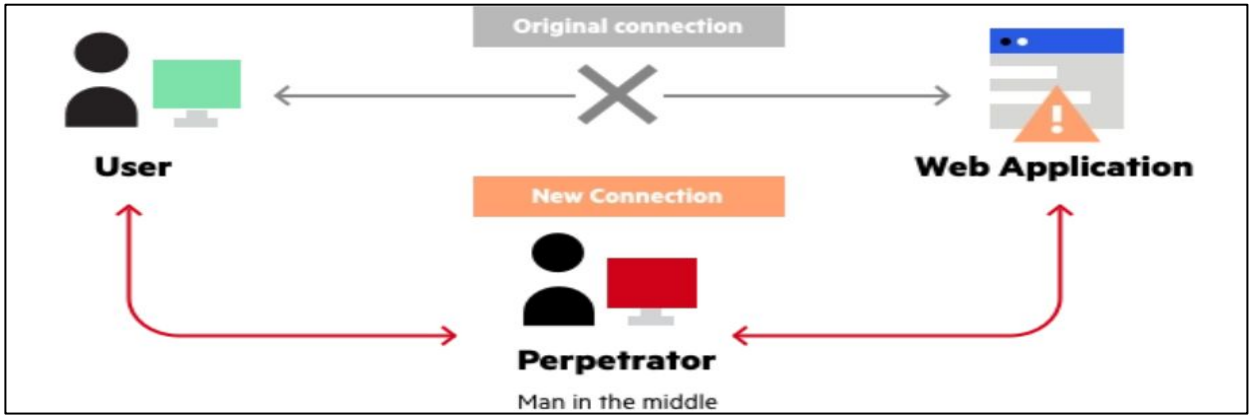
- **DoS Attack:** An attacker overwhelms a system, service, or network with excessive traffic, causing it to become unavailable to legitimate users.

- **DDoS Attack:** Similar to a DoS attack but launched from multiple compromised systems simultaneously, making it harder to defend against.



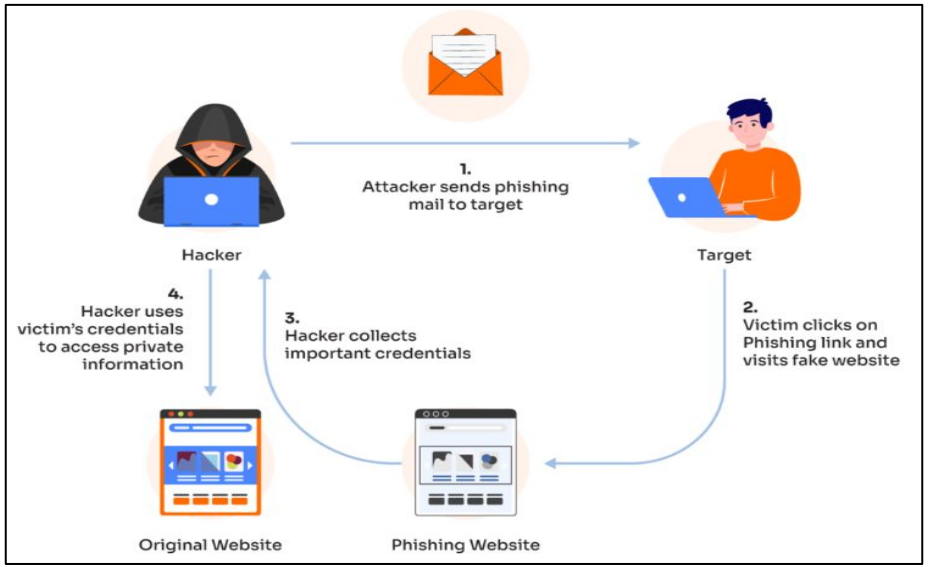
Man-in-the-Middle (MitM) Attacks

- **Definition:** An attacker intercepts and possibly alters the communication between two parties without their knowledge.
- **Example:** Eavesdropping on a communication session to steal sensitive information such as login credentials.



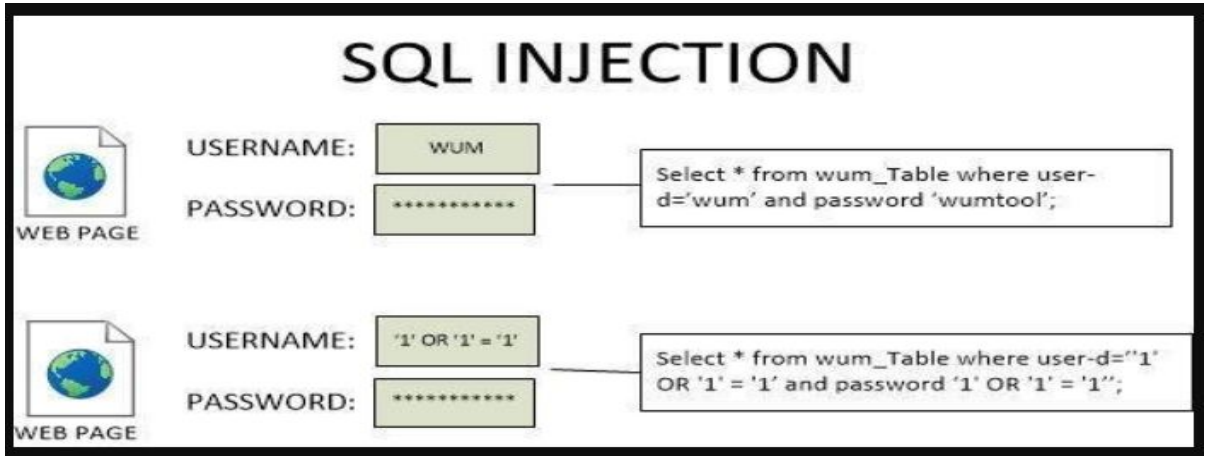
Phishing Attacks

- **Definition:** An attacker uses deceptive emails, messages, or websites to trick individuals into providing sensitive information such as usernames, passwords, or credit card numbers.
- **Example:** A fake email that appears to be from a legitimate organization asking the recipient to click on a link and enter their login details.



SQL Injection Attacks

- **Definition:** An attacker inserts malicious SQL code into a web application's input fields to manipulate the backend database and gain unauthorized access to data.
- **Example:** Retrieving or modifying sensitive data from a database by exploiting vulnerabilities in the application's input validation.

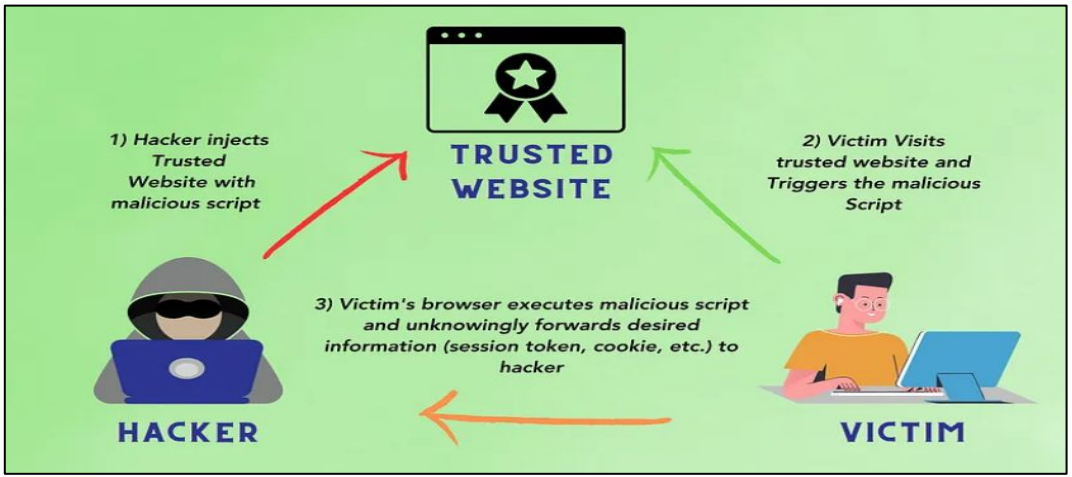


Cross-Site Scripting (XSS) Attacks

- **Definition:** An attacker injects malicious scripts into webpages viewed by other users, which then execute in the users' browsers and can steal information or perform actions on their behalf.

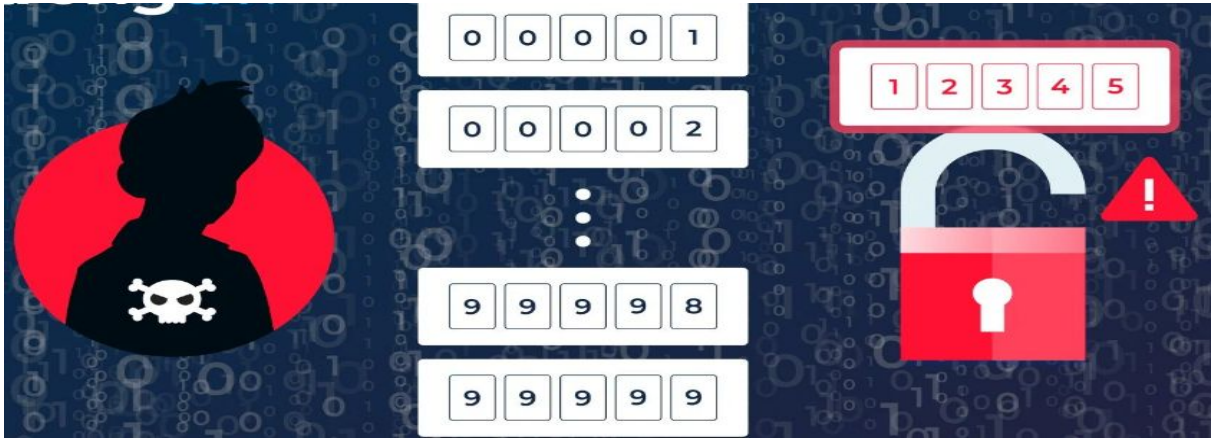
- Stored XSS: The malicious script is permanently stored on the target server.

- **Reflected XSS:** The malicious script is reflected off a web server, typically via a search or error message.



Password Attacks

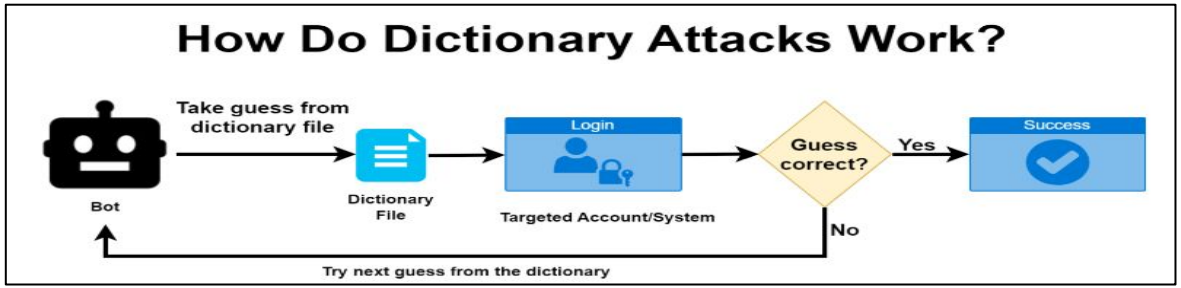
- **Brute-force:** An attacker systematically tries all possible combinations of passwords or encryption keys until the correct one is found.
- **Example:** Attempting to log into a user's account by trying different password combinations until the correct one is guessed.

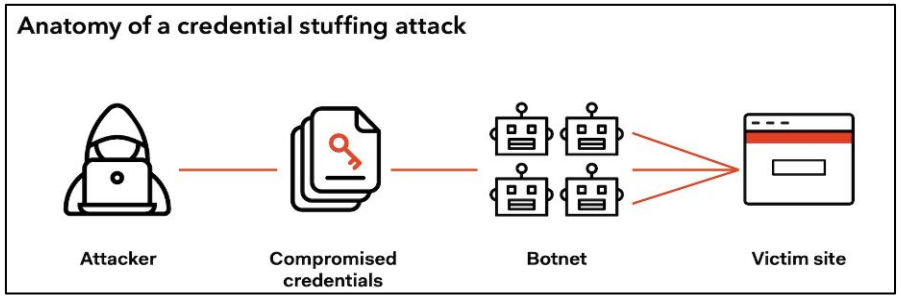


Password Attacks

- **Dictionary Attack:** Using a predefined list of commonly used passwords to attempt to gain access.

- **Credential Stuffing:** Using stolen username and password combinations from one breach to try and gain access to other accounts where the same credentials might be used.





Zero-Day Attacks

- **Definition:** An attack that exploits a previously unknown vulnerability in software or hardware, for which there is no current fix.
- **Example:** Exploiting a new vulnerability in a popular application before the developer has had a chance to patch it.

Zero-day

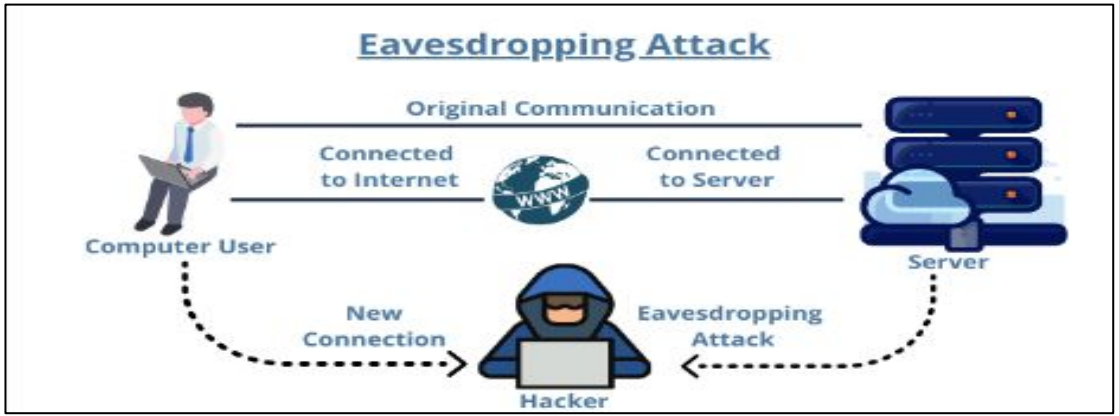
- "Zero-day" is a general word that refers to newly revealed security flaws that hackers can exploit to attack systems.
- The term "zero-day" alludes to the fact that the vendor or developer only recently discovered the fault, implying that they have "zero days" to repair it.
- A zero-day attack occurs when hackers exploit a weakness before engineers have time to fix it.

Zero-day terminologies

- A **zero-day vulnerability** is one that is discovered by attackers before the vendor is aware of it. Because suppliers are ignorant, there is no patch for zero-day vulnerabilities, making assaults more likely to succeed.
- A **zero-day exploit** is a tactic used by hackers to attack systems that have a previously unknown vulnerability.
- A **zero-day attack** is the use of a zero-day exploit to cause damage to or steal data from a vulnerable system.

Eavesdropping Attacks

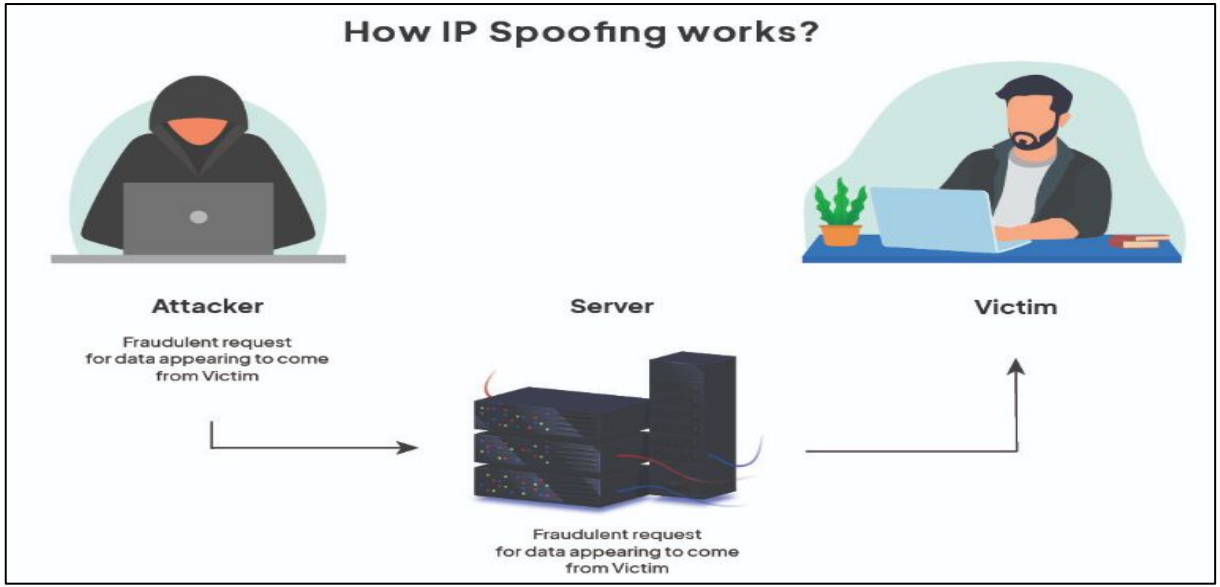
- **Definition:** An attacker secretly listens to private communications over a network.
- **Example:** Intercepting unencrypted communications over a public Wi-Fi network to steal sensitive information.



Spoofing Attacks

- **IP Spoofing:** An attacker sends packets from a false IP address to impersonate another device.

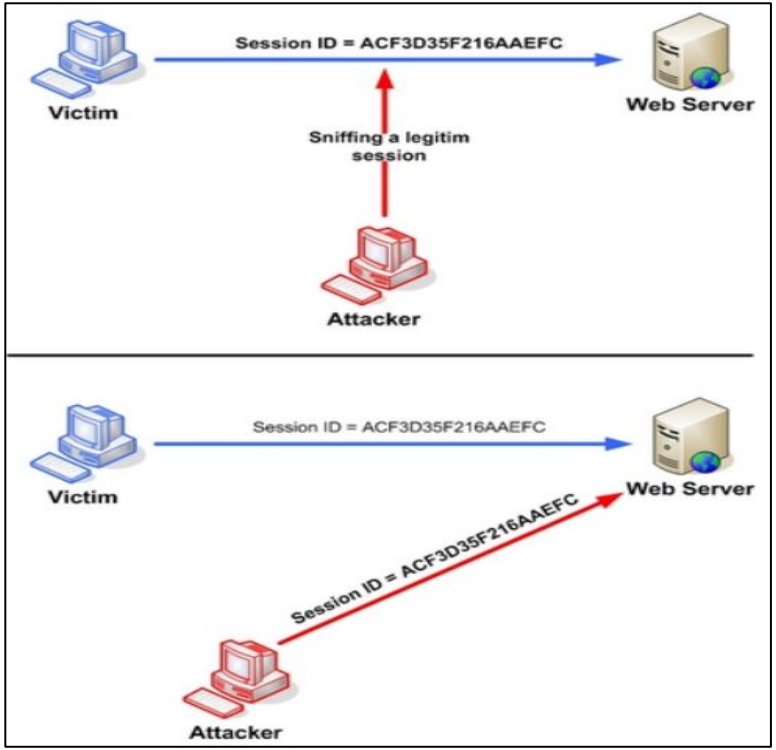
- **DNS Spoofing:** An attacker alters DNS records to redirect traffic from legitimate websites to malicious ones.



Session Hijacking

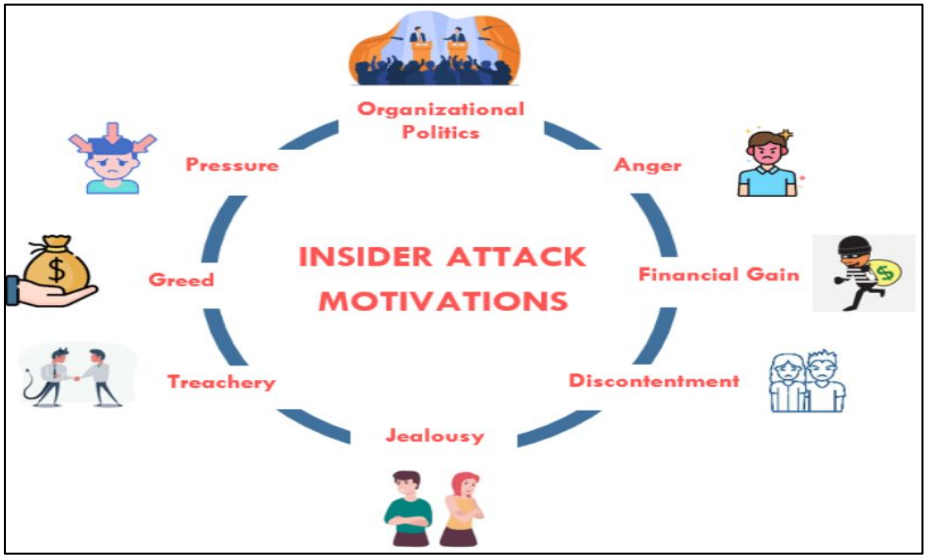
- **Definition:** An attacker takes control of a user's session by stealing or predicting the session token.

- **Example:** Gaining unauthorized access to a user's online account by hijacking their session after they have logged in.



Insider Threats

- **Definition:** Attacks that originate from within the organization by employees, contractors, or other insiders who have legitimate access to the network.
- **Example:** A disgruntled employee stealing sensitive data or sabotaging systems.



Social Engineering Attacks

- Social engineering is a manipulation technique that exploits human psychology to gain access to confidential information, networks, or physical locations. It often involves tricking individuals into breaking normal security procedures. Social engineering attacks rely on human error rather than vulnerabilities in software or systems. Here are some common methods of social engineering:

  - Phishing
  - Baiting
  - Quid Pro Quo
  - Vishing / Voice Phishing
  - Spear Phishing
  - Pretexting
  - Tailgating / Piggybacking

Social Engineering Attacks

1. **Phishing:** Attackers send fraudulent emails or messages that appear to be from reputable sources to trick individuals into revealing personal information, such as passwords or credit card numbers.
2. **Spear Phishing:** A more targeted form of phishing where attackers tailor their messages to a specific individual or organization, often using information gathered from social media or other sources.
3. **Baiting:** Attackers leave physical devices, like USB drives, in conspicuous locations. When someone finds and uses the device, malware is installed on their system.

Social Engineering Attacks

4. **Smishing(SMS Phishing):** Smishing is a form of phishing that uses mobile phones as the attack platform. The criminal executes the attack with an intent to gather personal information, including social insurance and/or credit card numbers. Smishing is implemented through text messages or SMS, giving the attack the name “SMiShing.”
5. **Vishing (Voice Phishing):** Attackers use phone calls to impersonate legitimate entities, like banks or tech support, to extract confidential information from targets.

Basics of Network

What is a network?

- A network is a collection of computers and devices interconnected by communication channels that allow them to share resources and information.
- Networks can range from a small home network to a large corporate network or even the global internet.

Types of Networks:

- **Personal Area Network (PAN):** Used for connecting devices in a very small area, like a few meters around a person. Bluetooth is an example.
- **Local Area Network (LAN):** Covers a small geographic area, like a home or office. Typically, it's used to connect computers and devices within a single location.
- **Metropolitan Area Network (MAN):** Spans a city or a large campus, larger than a LAN but smaller than a WAN.
- **Wide Area Network (WAN):** Covers a broad area, such as a city, country, or even global connections. The internet is the largest example of a WAN.

Network Topology

- Network topology refers to the arrangement of different elements like nodes, links, and devices in a computer network. It defines how these components are connected and interact with each other.
- Common types include point to point, bus, star, ring, mesh, and tree topologies, each with its own advantages and disadvantages.

Network Topology.

- **Point-to-point Topology** is a type of topology that works on the functionality of the sender and receiver. It is the simplest communication between two nodes, in which one is the sender and the other one is the receiver.
- **Bus Topology** is a network type in which every computer and network device is connected to a single cable. It is bi-directional.

Network Topology.

- **Ring Topology**, it forms a ring connecting devices with exactly two neighboring devices

- **Star Topology**, all the devices are connected to a single hub through a cable. This hub is the central node and all other nodes are connected to the central node.

Network Topology

- **Tree Topology,** this topology is the variation of the Star topology. This topology has a hierarchical flow of data.
- **Mesh Topology**, every device is connected to another device via a particular channel.
- **Hybrid Topology,** this topological technology is the combination of all the various types of topologies we have studied above. Hybrid Topology is used when the nodes are free to take any form.

Network Topology Types

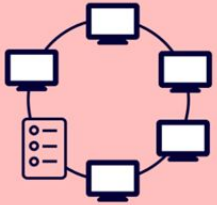
Point to point



Bus



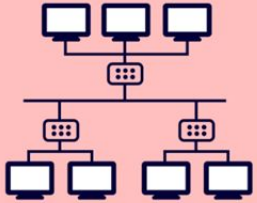
Ring



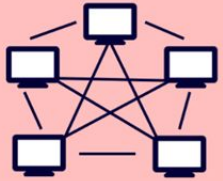
Star



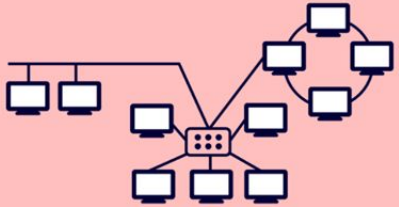
Tree



Mesh



Hybrid



IP Addressing

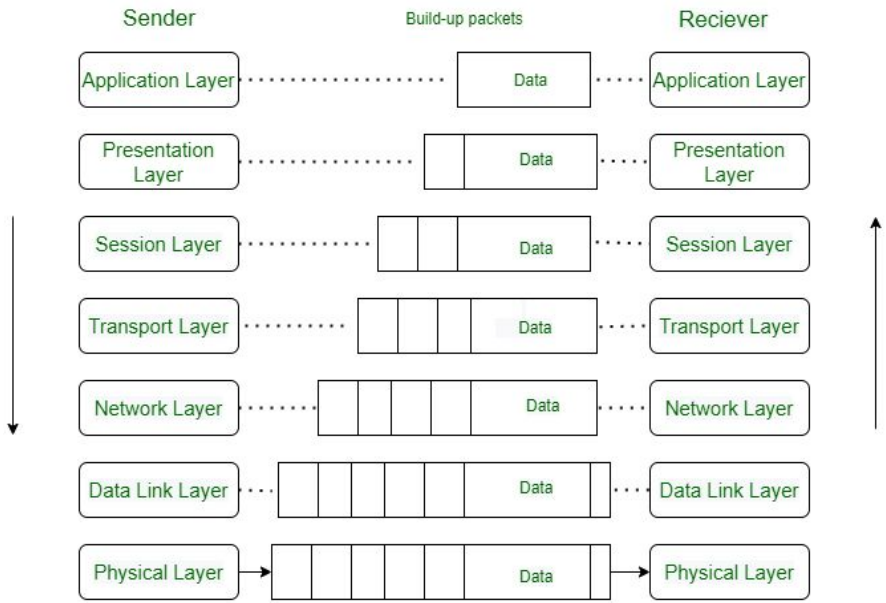
- Each device on a network has a unique identifier known as an IP address. It allows devices to locate and communicate with each other.
- **IPv4:** Uses a 32-bit address format (e.g., 192.168.1.1).
- **IPv6:** Uses a 128-bit address format, offering a larger address space (e.g., 2001:0db8:85a3:0000:0000:8a2e:0370:7334).

OSI Model

- **OSI stands for Open Systems Interconnection**, where open stands to say non-proprietary.
- It is a 7-layer architecture with each layer having specific functionality to perform.
- All these 7 layers work collaboratively to transmit the data from one person to another across the globe. The OSI reference model was developed by **ISO – 'International Organization for Standardization'**, in the year 1984.
- The OSI model provides a **theoretical foundation** for understanding **network communication**.

Data flows through the OSI model

- **Application Layer:** Applications create the data.
- **Presentation Layer:** Data is formatted and encrypted.
- **Session Layer:** Connections are established and managed.
- **Transport Layer:** Responsible for process to process and port to port communication.
- **Network Layer**: Segments are packaged into packets and routed.
- **Data Link Layer:** Packets are framed and sent to the next device.
- **Physical Layer:** Frames are converted into bits and transmitted physically.



Protocols

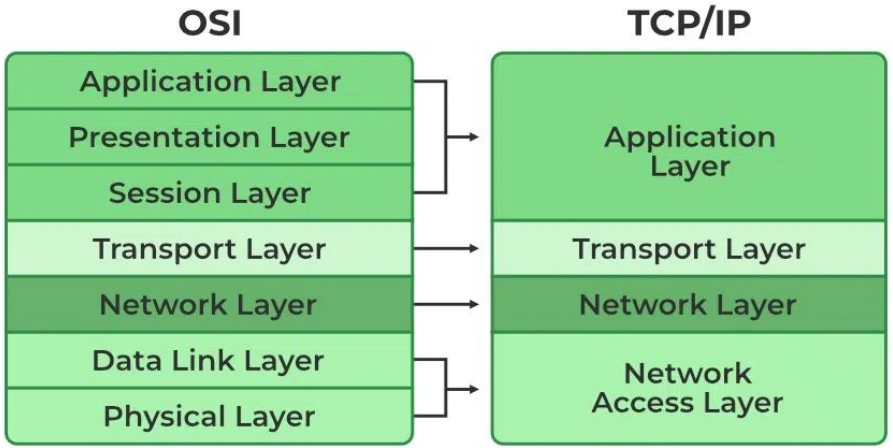
- Protocols and standards are important in computer networks.
- They are like the rules and guidelines that allow different devices and systems to communicate and work together smoothly.
- Protocols define how data is sent, received, and processed, while standards ensure that various technologies are compatible with each other.

TCP & IP

- TCP (Transmission Control Protocol) is one of the main protocols of the TCP/IP suite.
- Transmission Control Protocol (TCP) ensures reliable and efficient data transmission over the internet.
- Transmission Control Protocol (TCP) is a connection-oriented protocol for communications that helps in the exchange of messages between different devices over a network.
- Internet Protocol (IP) is a method that is useful for sending data from one device to another from all over the internet. It is a set of rules governing how data is sent and received over the internet.

TCP/IP

- The TCP/IP model is a fundamental framework for computer networking.
- It stands for Transmission Control Protocol/Internet Protocol, which are the core protocols of the Internet.
- This model defines how data is transmitted over networks, ensuring reliable communication between devices. It consists of four layers:
  - the Application Layer.
  - the Transport Layer,
  - the Network /Internet Layer,
  - the Link Layer,



Application Layer

- **Purpose:** This is the layer where end-user applications and protocols operate. It's responsible for providing network services directly to applications.
- **Protocols:**
  - **HTTP/HTTPS** (Hypertext Transfer Protocol/Secure): Used for web browsing.
  - **FTP** (File Transfer Protocol): Used for transferring files.
  - **SMTP** (Simple Mail Transfer Protocol): Used for email transmission.
  - **DNS** (Domain Name System): Translates domain names into IP addresses.

Transport Layer

- **Purpose:** Manages end-to-end communication between devices, providing error recovery and flow control.
- **Protocols:**
  - **TCP** (Transmission Control Protocol): Provides reliable, connection-oriented communication. It ensures that data packets are delivered in the correct order and without errors.
  - **UDP** (User Datagram Protocol): Provides a connectionless, less reliable communication service. It’s used where speed is more critical than reliability, such as streaming.

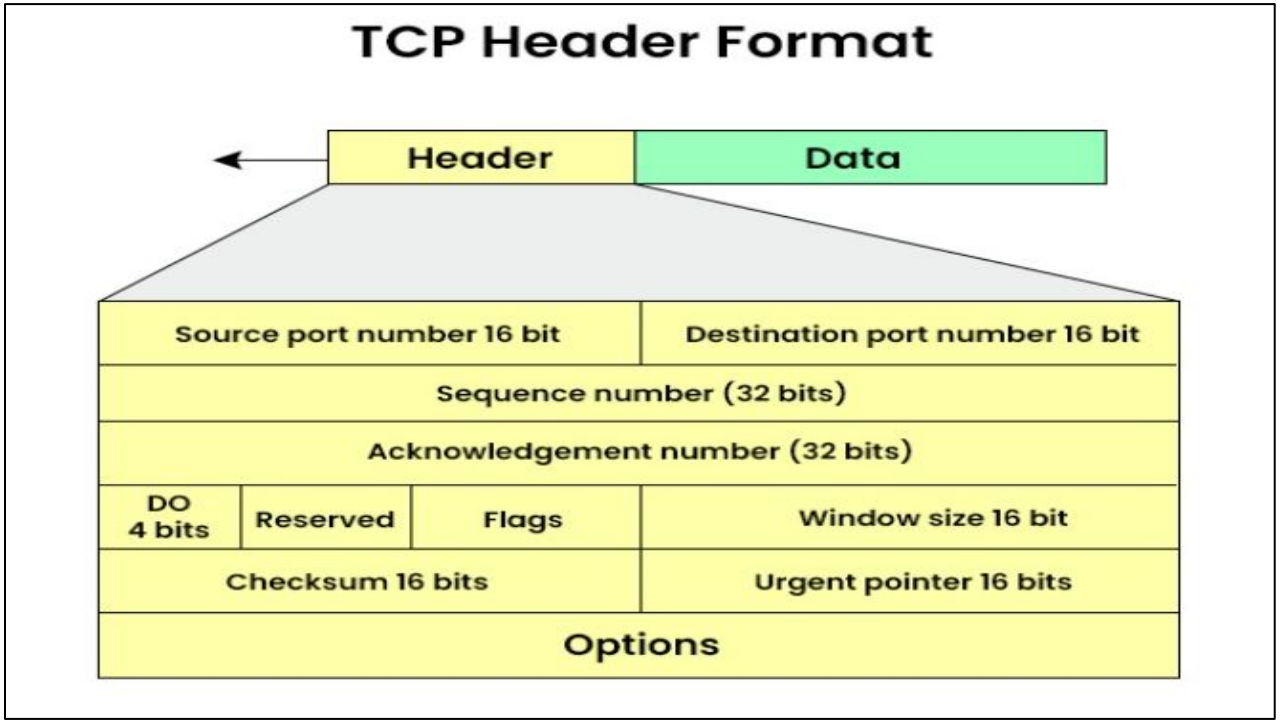
Internet Layer

- **Purpose:** Handles the logical addressing and routing of data packets across different networks.
- **Protocols:**
  - **IP** (Internet Protocol): Responsible for addressing and routing packets to ensure they reach the correct destination.
  - **IPv4**: Uses 32-bit addresses.
  - **IPv6**: Uses 128-bit addresses, providing a larger address space.
- **ICMP** (Internet Control Message Protocol): Used for network diagnostics and error reporting (e.g., ping).

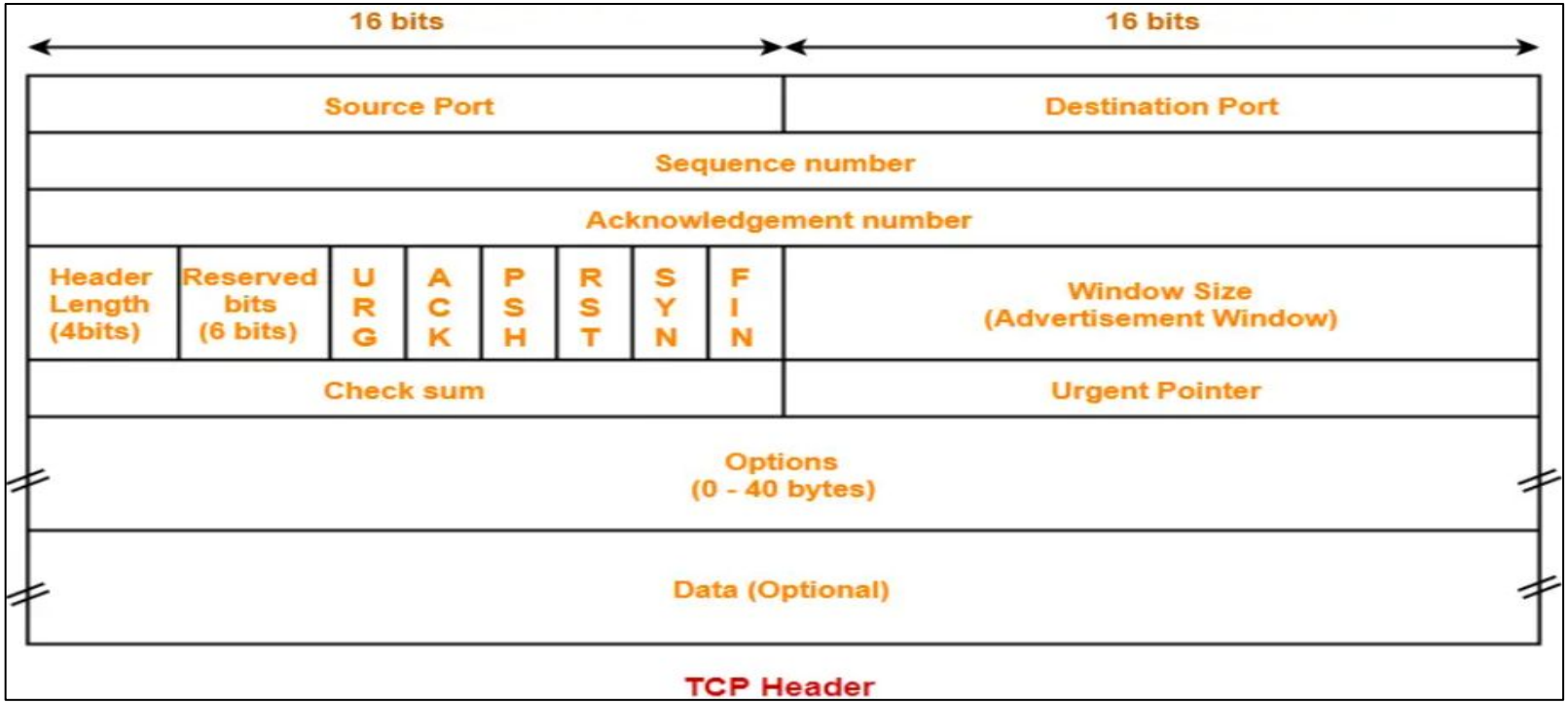
Network Access Layer

- **Purpose:** Manages physical network hardware and the data link protocols. It's responsible for the actual transmission of data over the physical network.
- **Protocols:**
  - **Ethernet**: Commonly used in local area networks (LANs).
  - **Wi-Fi**: Wireless networking protocol.
  - **PPP** (Point-to-Point Protocol): Used for direct connections between two nodes.

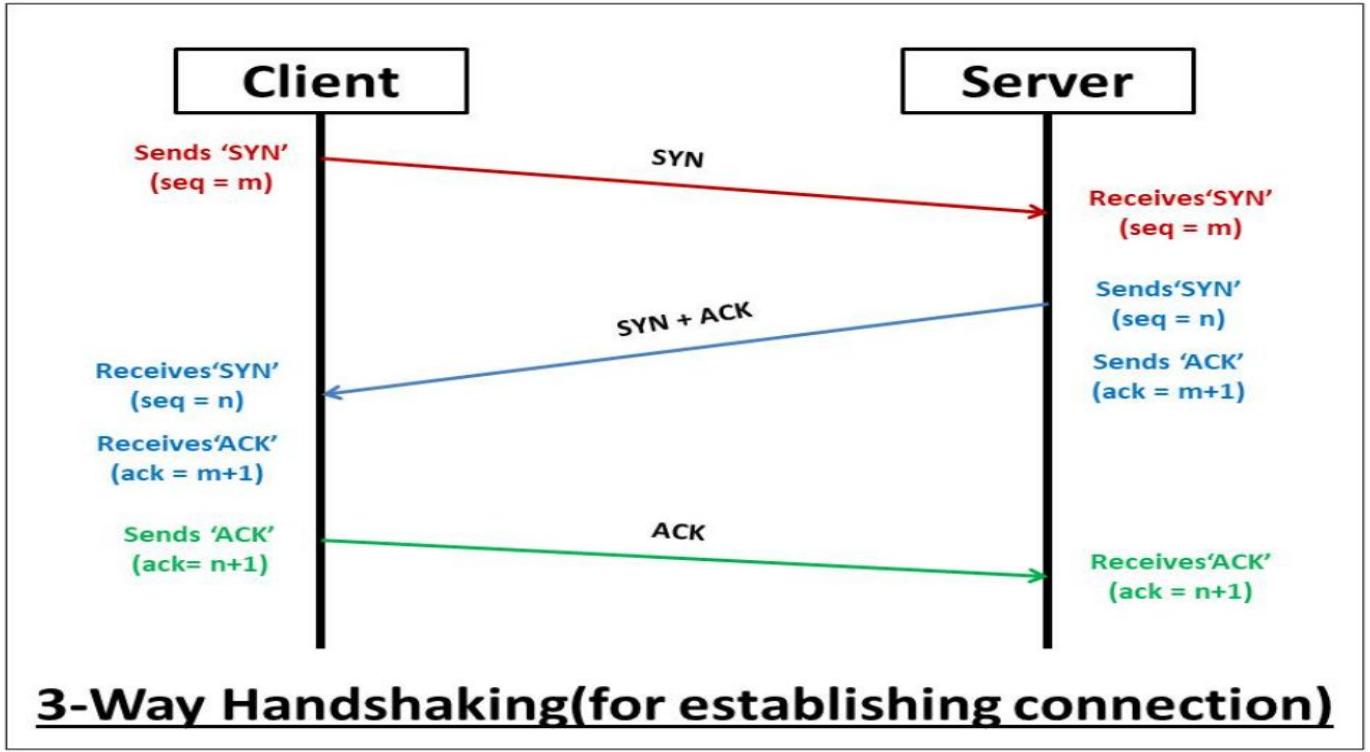
TCP structure



TCP Header


16 bits
16 bits
Source Port
Destination Port
Sequence number
Acknowledgement number
Header Length (4bits)
Reserved bits (6 bits)
URG
ACK
PSH
RST
SYN
FIN
Window Size (Advertisement Window)
Check sum
Urgent Pointer
Options (0 - 40 bytes)
Data (Optional)
TCP Header

TCP 3-way handshake



TCP and IP Header

